



- **Conceptos de Criptografía**
- **Normativa de firma electronica**
- **Firma electrónica**

1. CONCEPTOS DE CRIPTOGRAFIA
2. NORMATIVA DE FIRMA ELECTRONICA
3. CONCEPTOS DE FIRMA ELECTRONICA

PRINCIPALES CRITERIOS DE SEGURIDAD

- **Autenticación:** El receptor del mensaje puede asegurar la identidad del emisor. El emisor puede estar seguro de a quién envía el mensaje. Evita ataques de engaño o suplantación.
Ver Certificados Digitales
- **Confidencialidad:** Protección de la información frente a usos no autorizados. Sólo emisor y receptor pueden acceder al contenido del mensaje. Evita ataques de interceptación.
Ver cifrado simétrico/asimétrico
- **Integridad:** Protección de la información frente a cualquier tipo de alteración
Ver algoritmos MAC
- **No repudio:** Garantía de que el emisor o receptor no rechazan su envío o recepción
Ver firma-e
- **Control de acceso:** Protección de los recursos para evitar accesos no autorizados

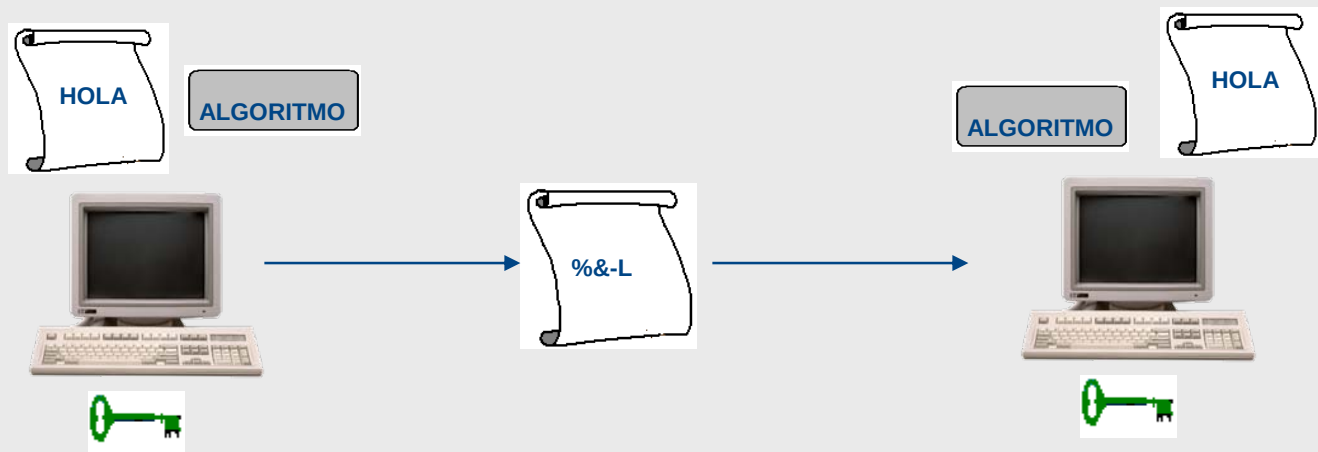
- **Información manuscrita:** Julio Cesar -- cifrado por sustitución
- **Información vía radio:** Segunda Guerra Mundial -- cifrado por transposición

CRIPTOGRAFÍA: Ciencia de escribir con clave secreta para mantener oculta determinada información a accesos no deseados.



ALGORITMOS SIMÉTRICOS

- Método que utiliza la misma clave para cifrar (encriptar) que para descifrar (desencriptar)



- ◆ Envío de la clave por un canal seguro
- ◆ Envío personal (uno a uno)
- ◆ Uso de claves de 128 bits +-

● DES, Triple DES (Data Encryption Standard).

- ◆ Desarrollado originalmente por IBM en 1976 y adoptado como estándar oficial
- ◆ Es el más utilizado.
- ◆ Divide mensaje en bloques de 64 bits y aplica interacciones múltiples con operaciones con clave de 56 bits.
- ◆ DES ha sido roto con 2^{56} combinaciones.
- ◆ T-DES, que aplica 3 veces DES. Clave de 168 bits y 2^{112} combinaciones.
- ◆ A T-DES no se le conoce ningún ataque con éxito.
- ◆ Es muy rápido, emplea sustituciones (confusión) y permutaciones (difusión).

● AES: Advanced Encryption Standard.

- ◆ Sistema de encriptación adoptado por el gobierno de Estados Unidos (FIPS-PUB 197) y fue propuesto por el NIST.
- ◆ Cifrado simétrico en bloques de 128 bits y con claves de 128, 192 o 256 bits.
- ◆ Este estándar contempla el algoritmo para 10, 12 o 14 vueltas aunque está previsto aumentarlas debido al éxito obtenido con criptoanálisis que encuentra coincidencia con 277 bloques bajo 256 claves y requiere sobre 2224 pasos para completarse.

● RESISTENCIA DE LOS ALGORITMOS CRIPTOGRÁFICOS

Tamaño de la clave:

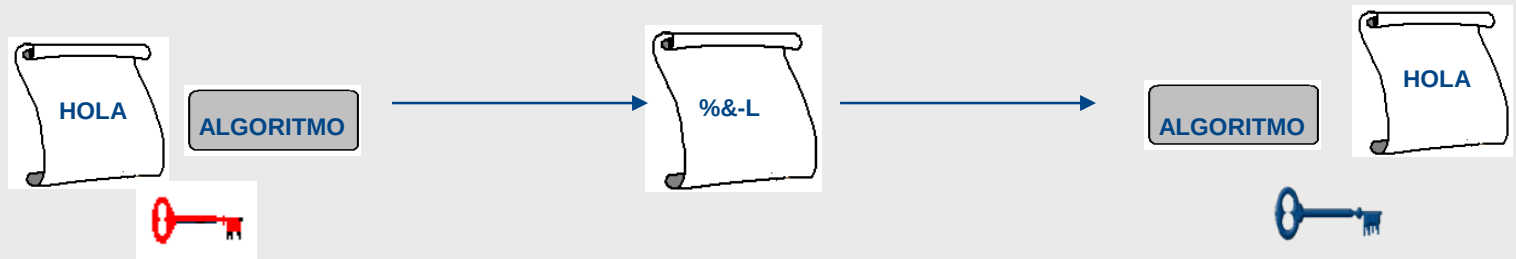
Número de claves posibles

● 32 bits		4.294.967.296
● 40 bits		1.099.511.627.776
● 56 bits		72.057.594.037.930.000
● 64 bits		18.446.744.073.710.000.000
● 80 bits		1.208.925.819.615.000.000.000.000
● 128 bits		340.282.366.920.900.000.000.000.000.000.000.000.000

¿ES SUFICIENTE CON EL ALGORITMO SIMÉTRICO?

ALGORITMOS ASIMÉTRICOS

- Surge como solución al problema de distribución de llaves.
- Método que utiliza dos claves, una para cifrar (encriptar) y otra para descifrar (desencriptar).
- Las dos claves están relacionadas matemáticamente y cumplen:
 - ◆ Los datos cifrados con una clave solo se descifran con la otra
 - ◆ Con una clave es imposible averiguar la otra.
- El método fue inventado en 1976 por Diffie y Hellman, para solucionar el problema del intercambio de la clave en la criptografía simétrica.
- Múltiples aplicaciones:
 - ◆ Confidencialidad. El emisor cifra con la clave pública del receptor y el receptor descifra con su clave privada. (SSL)
 - ◆ Autenticación.
 - ◆ Firma digital.



- **RSA.** Rivest-Shamir-Adleman.
 - ◆ Es el más extendido hoy día.
 - ◆ Se utilizan claves de 1024 bits para uso individual, y de 4096 para uso militar.
 - ◆ En la actualidad es computacionalmente intratable.
 - ◆ Su principal problema es que es muchísimo mas lento que el simétrico.
- **Curvas Elípticas:** ECDH / ECDSA a 256 / 384
- La criptografía asimétrica también se denomina de **Clave Pública:**
 - ◆ La clave 1 se mantiene como privada en poder del emisor y la clave 2 se difunde públicamente



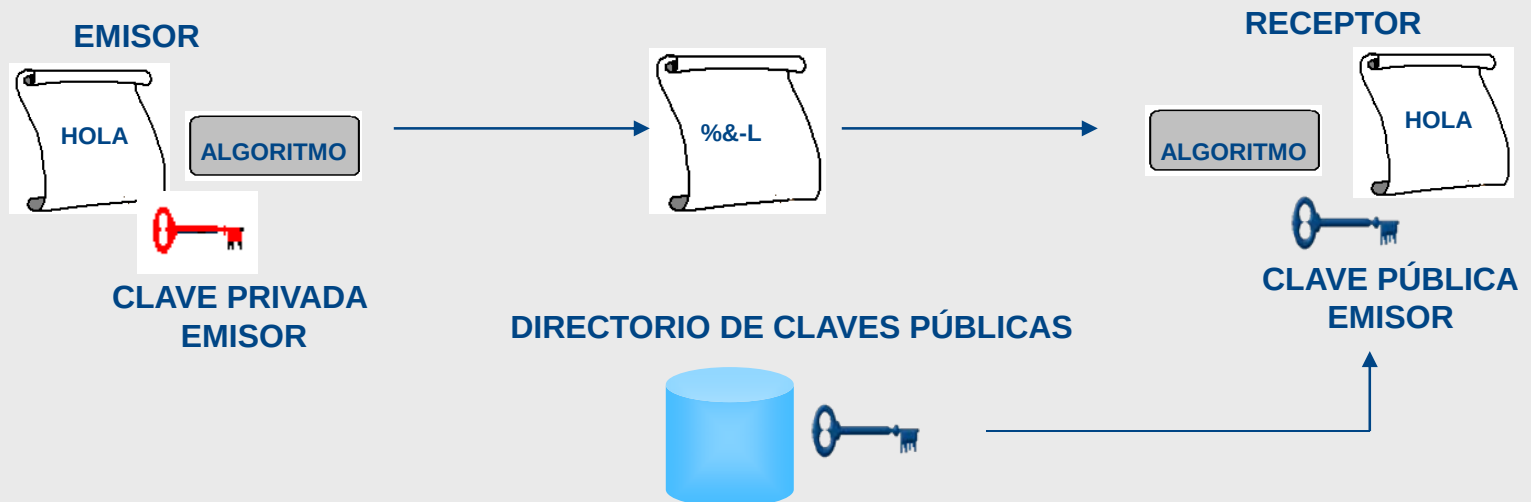
ALGORITMOS ASIMÉTRICOS

- Si queremos enviar un mensaje confidencial con destino a una persona específica, cifraremos el mensaje con la clave pública del destinatario.
- Sólo él podrá descifrar el contenido con su clave privada.



FIRMA DIGITAL

- Si queremos identificarnos sin lugar a dudas, cifraremos un mensaje con nuestra clave privada.
- Solo con nuestra clave pública y con ninguna otra podrá descifrarse el mensaje.
- Se detecta cualquier alteración de los datos firmados.
- Existe por tanto una vinculación unívoca entre datos firmados, firma y firmante.
- Este proceso de identificación se denomina FIRMA DIGITAL.



- Funciones resumen o hash, propiedades:
 - ◆ Dado un mensaje M de longitud L
 - $F(M) = H$, siendo H el resumen de M.
 - H identifica de manera unívoca el mensaje M.
 - H es siempre de longitud fija, independientemente del valor de L.
 - Dado M, es fácil calcular H.
 - Dado H, es imposible obtener M.
 - ◆ Las propiedades que deben de poseer las funciones resumen son:
 - **Que no sea reversible:** dada cualquier resumen H, es computacionalmente imposible encontrar un mensaje M tal que $F(M)=H$.
 - **Resistencia a colisión suave** (weak collision free): significa que dado un mensaje M, es computacionalmente imposible encontrar otro mensaje M' tal que $F(M) = F(M')$
 - **Resistencia a colisión fuerte** (strong collision free): significa que es computacionalmente imposible encontrar dos diferentes mensajes M, M' tal que $F(M) = F(M')$

- MD5 (*Message Digest Algorithm*)
 - ◆ Predecesores: MD2, MD4.
 - ◆ Diseñado por Ron Rivest.
 - ◆ Procesa bloques de 512 bits.
 - ◆ Produce una salida de 128 bits.
 - ◆ *Roto en la actualidad.*

- SHA-1/SHA-2 (*Secure Hash Algorithm*)
 - ◆ Diseñado por NSA (*National Security Agency*).
 - ◆ Incluido en el estándar DSS (*Digital Signature Standard*).
 - ◆ Proceso bloques de 512 bits.
 - ◆ Produce una salida de 160 bits.
 - ◆ *SHA1- Inseguro en la actualidad.*
 - ◆ Recomendados SHA-2: SHA-256, SHA-384, SHA-512.

- **Ejemplos de algoritmos de firma digital:**
 - ◆ sha1WithRsaEncryption: SHA1 (hash) y RSA (algoritmo asimétrico)
 - ◆ md5WithRsaEncryption: MD5 (hash) y RSA (algoritmo asimétrico)

Sin embargo,

¿ES SUFICIENTE CON EL ALGORITMO ASIMETRICO PARA LA TRANSMITIR DOCUMENTOS?

- ◆ Es un método muy lento, sobre todo para documentos largos

- **SOLUCIÓN: *Sobre Digital***

- ◆ Con el algoritmo asimétrico el emisor intercambiará con el receptor la clave simétrica que previamente habrá generado.
- ◆ Una vez transmitida de forma segura la clave simétrica, se cifrará la información con un algoritmo simétrico.
- ◆ La clave simétrica se cambiará cada nueva transmisión.
- ◆ No se necesita cifrar 'n' veces el documento original (en fragmentos)

1. CONCEPTOS DE CRIPTOGRAFIA
2. NORMATIVA DE FIRMA ELECTRONICA
3. CONCEPTOS DE FIRMA ELECTRONICA

Directiva Comunitaria de Firma Electrónica

● Artículo 1. Ámbito de aplicación

- ◆ Facilitar el uso de la firma electrónica y contribuir a su reconocimiento jurídico, de los Estados relativas a la materia de contratos.

● Artículo 2. Definiciones

- 1) «**firma electrónica**»: los datos en forma electrónica anejos a otros datos electrónicos o asociados de manera lógica con ellos, utilizados como medio de autenticación;
- 2) «**firma electrónica avanzada**»: la **firma electrónica que cumple** los requisitos siguientes:
 - a) estar vinculada al firmante de manera única;
 - b) permitir la identificación del firmante;
 - c) haber sido creada utilizando medios que el firmante puede mantener bajo su exclusivo control;
 - d) estar vinculada a los datos a que se refiere de modo que cualquier cambio ulterior de los mismos sea detectable;
- 3) «**firmante**»: la persona que está en posesión de un dispositivo de creación de firma y que actúa en su propio nombre o en el de la **entidad o persona física o jurídica** a la que representa;
- 4) «**datos de creación de firma**»: los datos únicos, tales como códigos o **claves criptográficas privadas**, que el firmante utiliza para crear la firma electrónica;
- 5) «**dispositivo de creación de firma**»: un programa informático configurado o un aparato informático configurado que sirve para aplicar los datos de creación de firma;

- 6) «**dispositivo seguro de creación de firma**»: un dispositivo de creación de firma que **cumple los requisitos enumerados en el anexo III**;
- 7) «**datos de verificación de firma**»: los datos, tales como códigos o **claves criptográficas públicas**, que se utilizan para verificar la firma electrónica;
- 8) «**dispositivo de verificación de firma**»: un programa informático configurado o un aparato informático configurado, que sirve para aplicar los datos de verificación de firma;
- 9) «**certificado**»: la certificación electrónica que **vincula unos datos de verificación de firma a una persona** y confirma la identidad de ésta;
- 10) «**certificado reconocido**»: el certificado que cumple los requisitos establecidos en el anexo I y es suministrado por un proveedor de servicios de certificación que cumple los requisitos establecidos en el anexo II;
- 11) «**proveedor de servicios de certificación (PSC)**»: la **entidad o persona física o jurídica que expide certificados** o presta otros servicios en relación con la firma electrónica;
- 12) «**producto de firma electrónica**»: el programa informático o el material informático, o sus componentes específicos, que se destinan a ser utilizados por el proveedor de servicios de certificación para la prestación de servicios de firma electrónica o que se destinan a ser utilizados para la creación o la verificación de firmas electrónicas;
- 13) «**acreditación voluntaria**»: todo permiso que establezca derechos y obligaciones específicas para la prestación de servicios de certificación, que se concedería, a petición del proveedor de servicios de certificación interesado, por el organismo público o privado encargado del establecimiento y supervisión del cumplimiento de dichos derechos y obligaciones.

● **Artículo 3. Acceso al mercado**

- ◆ **Los Estados miembros** no condicionarán la prestación de servicios de certificación a la obtención de autorización previa, aunque sí **podrán establecer o mantener sistemas voluntarios de acreditación destinados a mejorar los niveles de provisión de servicios de certificación**.
- ◆ Los Estados miembros **no podrán limitar el número de proveedores de servicios de certificación acreditados** amparándose en la Directiva.

● Artículo 7. Aspectos internacionales

- ◆ Los Estados miembros velarán por que los certificados expedidos al público como **certificados reconocidos** por un proveedor de servicios de certificación establecido en un tercer país, **sean reconocidos como jurídicamente equivalentes a los expedidos por un proveedor de servicios de certificación establecido en la Comunidad si se cumple** alguna de las condiciones siguientes:
 - que el proveedor de servicios de certificación **cumpla los requisitos establecidos en la presente Directiva y haya sido acreditado en el marco de un sistema voluntario de acreditación establecido en un Estado miembro**;
 - **que un proveedor de servicios de certificación establecido en la Comunidad**, que cumpla las prescripciones de la presente Directiva, **avale el certificado**;
 - que el certificado o el proveedor de servicios de certificación estén **reconocidos en virtud de un acuerdo bilateral o multilateral entre la Comunidad y terceros países** u organizaciones internacionales.

- **ANEXO I. Recoge los requisitos que deben contener los certificados reconocidos**
 - **ANEXO II. Recoge los requisitos de los proveedores de servicios de certificación que expiden certificados reconocidos**
 - **CWA 14167-1** (marzo de 2003): security requirements for trustworthy systems managing certificates for electronic signatures — Part 1: System Security Requirements
 - **CWA 14167-2** (marzo de 2002): security requirements for trustworthy systems managing certificates for electronic signatures — Part 2: cryptographic module for CSP signing operations — Protection Profile (MCSO-PP)
 - **ANEXO III. Requisitos de los dispositivos seguros de creación de firma electrónica**
 - **CWA 14169** (marzo de 2002): secure signature-creation devices.
 - **ANEXO IV. Recomendaciones para la verificación segura de firma**
- (Decisión Decisión 2003/511/CE relativa a la publicación de los números de referencia de las normas que gozan de reconocimiento general para productos de firma electrónica)**

Relación de normas generadas por EESSI

CEN/TC

- CWA 14355 Guidelines for the implementation of Secure Signature Creation Devices
- **CWA 14167-1/4 Security Requirements for Trustworthy Systems Managing Certificates for Electronic Signatures.**
- **CWA 14169 Secure Signature-Creation Devices "EAL 4+"**
- CWA 14170 Security Requirements for Signature Creation Applications
- CWA 14890-1/2 Application Interface for smart cards used as Secure Signature Creation Devices
- CWA 14172 -1/8 EESSI Conformity Assessment Guidance
- CWA 14365-1/2 Guide on the Use of Electronic Signatures
- **CWA 14171 General guidelines for electronic signature verification**

ETSI - ESI

- **40 normas**, definitivas y en curso. Consultar: <http://portal.etsi.org/esi/el-sign.asp>

La Ley 59/2003 de Firma Electrónica

● **Artículo 1: Objeto.**

- ◆ Esta ley regula la firma electrónica, su eficacia jurídica y la prestación de servicios de certificación.

● **Artículo 2. Prestadores de Servicios de Certificación**

- ◆ Aplica a los prestadores de servicios de certificación (PSC) establecidos en España.
- ◆ Persona física o jurídica que expide certificados electrónicos o presta otros servicios en relación con la firma electrónica.
- ◆ Obliga a los PSCs a efectuar una tutela y gestión permanente de los certificados electrónicos que expiden: **Declaración de Prácticas de Certificación.**
- ◆ Han de mantener servicio de consulta del estado de vigencia de los certificados y guardar información de los certificados durante 15 años.
- ◆ Se elimina el registro de PSCs, y se sustituye por una difusión de información de estos. Se favorece la autoregulación basada en esquemas voluntarios de acreditación y certificaciones o sellos de calidad.

Relación de PSCs del Ministerio de Industria, Turismo y Comercio,

MINISTERIO DE INDUSTRIA, TURISMO Y COMERCIO



PRESTADORES DE SERVICIOS DE CERTIFICACIÓN DE FIRMA ELECTRÓNICA

Resultado de la Consulta

✓ Servicios de certificación basados en certificados reconocidos

Prestadores

AC ABOGACÍA

ANCERT - Agencia Notarial de Certificación

ANF AC

Autoridad de Certificación de la Comunidad Valenciana (ACCV)

BANESTO CA

CAMERFIRMA

CATCert

CERES Fábrica Nacional de Moneda y Timbre - Real Casa de la Moneda (FNMT-RCM)

CICCP

FIRMAPROFESIONAL

Izenpe, S.A

✓ Servicios de certificación basados en certificados no reconocidos

Prestadores

CERES Fábrica Nacional de Moneda y Timbre - Real Casa de la Moneda (FNMT-RCM)

✓ Servicios de validación temporal

Prestadores

Autoridad de Certificación de la Comunidad Valenciana (ACCV)

CERES Fábrica Nacional de Moneda y Timbre - Real Casa de la Moneda (FNMT-RCM)

✓ Otros servicios

Prestadores

CERES Fábrica Nacional de Moneda y Timbre - Real Casa de la Moneda (FNMT-RCM)

FIRMAPROFESIONAL

La Ley 59/2003 de Firma Electrónica

● **Artículo 3: Firma electrónica, y documentos firmados electrónicamente.**

- ◆ **Definiciones** coincidentes con Artículo 2 de Directiva Comunitaria.
- ◆ **Sólo la firma electrónica reconocida, tiene el mismo valor que la manuscrita**
- ◆ Un **documento electrónico** es el redactado en soporte electrónico y que incorpore datos firmados electrónicamente.
- ◆ **No se negarán efectos jurídicos a una firma electrónica que no reúna los requisitos de firma electrónica reconocida** en relación a los datos a los que esté asociada por el mero hecho de presentarse en forma electrónica. (igual que en la Directiva)

● **Artículo 4. Empleo de la firma electrónica en el ámbito de las Administraciones públicas.**

- ◆ **Las AAPP, podrán establecer condiciones adicionales a la utilización de la firma electrónica en los procedimientos.** Eje. Fechado electrónico.
- ◆ Estas condiciones serán **objetivas, proporcionadas, transparentes y no discriminatorias y no deberán obstaculizar la prestación de servicios de certificación** al ciudadano cuando intervengan distintas AAPP nacionales o del Espacio Económico Europeo.
- ◆ **Se dictarán a propuesta conjunta del MAP y de Ciencia y Tecnología y previo informe del Consejo Superior Administración Electrónica.**

CERTIFICADOS RECONOCIDOS

- Son aquellos **expedidos por un PSC que cumpla los requisitos establecidos en esta ley.**
- Han de **incorporar, al menos**, la siguiente información:
 - ◆ La indicación de que se expiden como tales.
 - ◆ El código identificativo único del certificado.
 - ◆ La identificación del prestador de servicios de certificación que expide el certificado y su domicilio.
 - ◆ La firma electrónica avanzada del prestador de servicios de certificación que expide el certificado.
 - ◆ La identificación del firmante, en el supuesto de **personas físicas**, por su nombre y apellidos y su número de documento nacional de identidad o a través de un seudónimo que conste como tal de manera inequívoca y, en el supuesto de **personas jurídicas**, por su denominación o razón social y su código de identificación fiscal.
 - ◆ Los datos de verificación de firma que correspondan a los datos de creación de firma que se encuentren bajo el control del firmante.
 - ◆ El comienzo y el fin del período de validez del certificado.
 - ◆ Los límites de uso del certificado, si se establecen.
 - ◆ Los límites del valor de las transacciones para las que puede utilizarse el certificado, si se establecen.

LAECSP- TÍTULO SEGUNDO: Identificación y Autenticación

Regla general: Las AAPPs admitirán sistemas de firma electrónica que sean conformes a lo establecido en la Ley 59/2003, de 19 de diciembre, de Firma Electrónica y resulten adecuados para garantizar la identificación, y en su caso la autenticidad e integridad de los documentos electrónicos

Ciudadanos. Sistemas de firma electrónica:

- Firma electrónica del DNle
- Sistema de firma electrónica avanzado
certificados electrónicos reconocidos
- Otros sistemas:
 - Claves concertadas en registro previo.
 - Aportación de información conocida por ambas partes.

AA.PP's. Sistemas de identificación electrónica:

- Sistemas de firma electrónica basados en la utilización de certificados de dispositivo seguro.
- Sistemas de firma para actuación automatizada.
- Firma electrónica del personal al servicios de las AA.PP's.
- Intercambio de datos en entornos cerrados .

TÍTULO SEGUNDO: Identificación electrónica AA.PP's y autenticación

- Identificación de sedes electrónicas: Mediante sistemas de firma electrónica basados en certificados de dispositivo seguro.

- En la actuación administrativa automatizada, se admite:

- ❖ Sello electrónico basado en certificado electrónico (con NIF).
- ❖ Código seguro de verificación vinculado a la AA.PP.
- ❖ La relación de sellos electrónicos usados por cada AA.PP. deberá ser pública y accesible.
- ❖ Los sellos electrónicos deberán ser verificables.

TÍTULO SEGUNDO:

Archivo y expediente electrónico



ARCHIVO

- Se admite el archivo electrónico para todos los documentos utilizados en actuaciones administrativas.
- El archivo electrónico de documentos que afecten a derechos de los particulares, será posible si se asegura la identidad e integridad de la información necesaria para reproducirlo.
- Las medidas de seguridad de los archivos electrónico garantizarán: la integridad, autenticidad, confidencialidad, calidad, protección y conservación del documento, así como identificarán y controlarán a los usuarios que accedan.

EXPEDIENTE

- Expediente electrónico es el conjunto de documentos electrónicos de un procedimiento.
- Cada expediente tendrá un índice firmado electrónicamente. Un documento puede formar parte de varios expedientes.
- Se admite que la remisión de un expediente se sustituya por la puesta a disposición del expediente electrónico. El interesado puede obtener copia.

TÍTULO III - Identificación y autenticación

CAPÍTULO II- Identificación y autenticación en el acceso electrónico de los ciudadanos

Artículo 10. *Firma electrónica de los ciudadanos.*

1. Las personas físicas podrán utilizar para relacionarse electrónicamente con la Administración General del Estado y los organismos públicos vinculados o dependientes, los sistemas de firma electrónica incorporados al Documento Nacional de Identidad, en todo caso, y los sistemas de firma electrónica avanzada admitidos, a los que se refiere el artículo 13.2.b) de la Ley 11/2007, de 22 de junio.
2. Las personas jurídicas y entidades sin personalidad jurídica podrán utilizar sistemas de firma electrónica de persona jurídica o de entidades sin personalidad jurídica para todos aquellos procedimientos y actuaciones de la Administración General del Estado para los que se admitan.
3. En caso de no admisión, la sede electrónica correspondiente deberá facilitar sistemas alternativos que permitan a las personas jurídicas y a las entidades sin personalidad jurídica el ejercicio de su derecho a relacionarse electrónicamente con la Administración General del Estado.

Artículo 11. *Otros sistemas de firma electrónica.*

1. La admisión de otros sistemas de firma electrónica a la que se refiere el artículo 13.2.c) de la Ley 11/2007, de 22 de junio, deberán aprobarse mediante orden ministerial, o resolución del titular en el caso de los organismos públicos, previo informe del Consejo Superior de Administración Electrónica.

Artículo 16. *Identificación y autenticación de los ciudadanos por funcionario público.*

1....se requerirá que el funcionario público habilitado esté dotado de un sistema de firma electrónica admitido por el órgano u organismo público destinatario de la actuación para la que se ha de realizar la identificación o autenticación. El ciudadano, por su parte, habrá de identificarse ante el funcionario y prestar consentimiento expreso, debiendo quedar constancia de ello para los casos de discrepancia o litigio.

2.El Ministerio de la Presidencia mantendrá actualizado un registro de los funcionarios habilitados en la Administración General del Estado...

CAPÍTULO II - Identificación y autenticación de sedes electrónicas y de las comunicaciones que realicen los órganos

Artículo 17. *Identificación de sedes electrónicas de la Administración General del Estado y de sus organismos públicos vinculados o dependientes.*

Artículo 18. *Certificados de sede electrónica de la Administración General del Estado y de sus organismos públicos vinculados o dependientes.*

3. El Esquema Nacional de Seguridad, al que se refiere el artículo 42 de la Ley 11/2007, de 22 de junio, determinará las características y requisitos que cumplirán los sistemas de firma electrónica, los certificados y los medios equivalentes que se establezcan en las sedes electrónicas para la identificación y garantía de una comunicación segura.

Artículo 19. *Sistemas de firma electrónica mediante sello electrónico.*

Artículo 21. *Firma electrónica mediante medios de autenticación personal.*

- a) Firma basada en el Documento Nacional de Identidad electrónico.
- b) Firma basada en certificado de empleado público al servicio de la Administración General del Estado expresamente admitidos con esta finalidad.
- c) Sistemas de código seguro de verificación, en cuyo caso se aplicará, con las adaptaciones correspondientes, lo dispuesto en el artículo 20.

Artículo 22. *Características de los sistemas de firma electrónica basados en certificados facilitados al personal de la Administración General del Estado o de sus organismos públicos.*

CAPÍTULO III- Disposiciones comunes a la identificación y autenticación y condiciones de interoperabilidad

Artículo 23. *Obligaciones de los prestadores de servicios de certificación*

Artículo 24. *Política de firma electrónica y de certificados.*

... la política de firma electrónica y certificados deberá contener en todo caso:

- a) Los requisitos de las firmas electrónicas presentadas ante los órganos de la Administración General del Estado y de sus organismos públicos.
- b) Las especificaciones técnicas y operativas para la definición y prestación de los servicios de certificación asociados a las nuevas formas de identificación y autenticación de la Administración General del Estado recogidas en el presente real decreto.
- c) La definición de su ámbito de aplicación.

Artículo 25. *Plataformas de verificación de certificados y sistema nacional de verificación.*

CAPÍTULO IX

Firma electrónica y certificados

Artículo 18. *Interoperabilidad en la política de firma electrónica y de certificados.*

1. La Administración General del Estado definirá una política de firma electrónica y de certificados que servirá de marco general de interoperabilidad para la autenticación y el reconocimiento mutuo de firmas electrónicas dentro de su ámbito de actuación. No obstante, dicha política podrá ser utilizada como referencia por otras Administraciones públicas para definir las políticas de certificados y firmas a reconocer dentro de sus ámbitos competenciales.
- ...
4. Los perfiles comunes de los campos de los certificados definidos por la política de firma electrónica y de certificados posibilitarán la interoperabilidad entre las aplicaciones usuarias...
5. La política de firma electrónica y de certificados, mencionada en el apartado primero del presente artículo, establecerá las características técnicas y operativas de la lista de prestadores de servicios de certificación de confianza que recogerá los certificados reconocidos e interoperables entre las Administraciones públicas y que se consideren fiables para cada nivel de aseguramiento concreto, tanto en el ámbito nacional como europeo. La lista que establezca la Administración General del Estado podrá ser utilizada como referencia por otras Administraciones públicas para definir sus listas de servicios de confianza para aplicación dentro de sus ámbitos competenciales.

Disposición transitoria segunda. *Uso de medios actualmente admitidos de identificación y autenticación.*

De acuerdo con lo previsto en el artículo 19 de la Ley 11/2007, de 22 de junio, y en la disposición transitoria primera del Real Decreto 1671/2009, de 6 de noviembre, se establece un plazo de adaptación de veinticuatro meses en el que se podrá seguir utilizando los medios actualmente admitidos de identificación y firma electrónica.

Interoperabilidad de la firma electrónica

- Hay una gran heterogeneidad en la aplicación de firma-e: formatos, modalidades, algoritmos, ...
- Es necesario definir “las reglas del juego” en un entorno de aplicación de firma-e
- Una política de firma-e es:
 - ◆ Un documento que contiene una serie de normas relativas a la firma electrónica, organizadas alrededor de los conceptos de generación y validación de firma
 - ◆ Orientada a un contexto particular (contractual, jurídico, legal, ...),
 - ◆ Define las reglas y obligaciones para todos los actores involucrados en dicho proceso (emisor, receptor y tercera parte).
 - ◆ Procedimiento normalizado para determinar la validez de la firma electrónica para una transacción en particular.

La finalidad de una política de firma es reforzar la confianza en las transacciones electrónicas a través de una serie de condiciones para un contexto dado, el cual puede ser una transacción determinada, un régimen legal, un rol que asuma la parte firmante, ...

Interoperabilidad de la firma electrónica

- ◆ Elaborar una propuesta de normalización sobre documentación electrónica y política de firma electrónica para la Administración pública estatal (APE).
- ◆ **Alcance**
 - Estructura del documento electrónico.
 - Expediente electrónico
 - Archivado
 - ◆ Formatos de los ficheros admitidos por la política de firma.
 - ◆ Estructura del documento electrónico: CAdES, XAdES, b64, attached, factura-e enveloped
 - ◆ Extensión normalizada para los documentos firmados: extensión 'xsig' y 'csig'
- ◆ **Reglas de creación y validación de firma.**
 - ◆ Referencia a la política de firma: incorporar la referencia (URL) a la política aplicada..
 - ◆ Algoritmos utilizados y longitudes mínimas de las claves: seguridad genética (ETSI TS 102 176-1) y de alta seguridad (guía CCN-STIC 205)
 - ◆ Métodos de obtención de información de revocación: OCSP y CRLs.. Validación histórica.
 - ◆ Dato obligatorio en firmas: Formato del documento original.
 - ◆ Datos opcionales: en firmas: Rol de la persona en la firma electrónica., acción del firmante y lugar geográfico donde se ha realizado la firma..
 - ◆ Sellado de tiempo: Referencia temporal obligatoria, sellado de tiempo, opcional. Cumplimiento de norma ETSI TS 102 023.

● Política de firma-e de la AGE

- ◆ Gestión de políticas de firma: automatización, formato, difusión, consulta, ...
- ◆ Homogeneización de la firma electrónica para el ciudadano: visores y validadores
- ◆ Se crearán los documentos en XML y ASN.1 para la implementación de las políticas.
- ◆ Aplicación de especificaciones técnicas:
 - ETSI TR 102 041 - Describe los posibles contenidos, usos y soporte legal de una política.
 - ETSI TR 102 045 - Analiza cuestiones de política de firma electrónica para entornos complejos.
 - ETSI TR 102 038 - Describe el formato y los contenidos de una política empleando sintaxis XML.
 - ETSI TR 102 272 - Describe el formato y los contenidos de una política empleando sintaxis ASN.1.

● Otras políticas

- ◆ Política de firma de la factura electrónica: *facturae*
 - ◆ http://www.facturae.es/Documentacion/PolíticasFirma/Version3_1/

● Implementación

- ◆ Las políticas se han de describir en formatos normalizados (eje. - ETSI TR 102 041, Electronic Signatures and Infrastructures (SEI); Signature policies report.)
- ◆ Las políticas se definen mediante un identificador único asociado a la entidad emisora de la política: OID.
- ◆ Hay firmas avanzadas que incluyen la política: EPES (Explicit Policy based Electronic Signature)
- ◆ Para que se usen y apliquen en implementaciones es necesario trasladarlas a lenguajes formales:
 - ASN.1 -> eje. CAdES-EPES
 - XML -> eje. XAdES-EPES
- ◆ Validación de firmas
 - Si se incluye la política, las validaciones de firma han de comprobar que es válida:
 - ¿Está en un formato admitido en la política?
 - ¿Dispone de sello de tiempo?
 - ¿Incluye el rol del firmante?
 - ¿Es detached?...
 - ¿Con qué certificados se ha realizado la firma?

ASPECTOS GENERALES

De aplicación para toda la **Administración General del Estado**.

Puede convivir junto con otras **políticas particulares** para transacciones determinadas en un contexto concreto. Las políticas particulares de firma deberán estar en todo caso basadas en la política marco o global y ajustarse a lo establecido en esta resolución/orden.

Se publicará en el **Punto de acceso general** de la Administración General del Estado.

Deberán estar disponibles en formato **legible**, de modo que puedan ser aplicadas en un contexto concreto para cumplir con los requerimientos de creación y validación de firma electrónica.

Para facilitar el procesado automático de la firma electrónica, la política de firma deberá implementarse a su vez en un formato que pueda ser entendido por los sistemas encargados de la creación y validación de firma electrónica. Se recomienda que esté disponible al menos en formato **“XML” y en formato “ASN.1”**.

Se identificarán con un identificador único **OID**, que deberá incluirse obligatoriamente en la firma electrónica, empleando el campo correspondiente.

Corresponde al **Consejo Superior de Administración Electrónica** aprobar modificaciones a la política de firma de la Administración General del Estado si se considera necesario por razones de interoperabilidad o debido a cambios tecnológicos

Formatos admitidos de firma electrónica

- XAdES (XML Advanced Electronic Signatures), según especificación técnica ETSI TS 101 903, versión 1.2.2 y versión 1.3.2.

- CAdES (CMS Advanced Electronic Signatures), según especificación técnica ETSI TS 101 733, versión 1.6.3, versión 1.7.3 y versión 1.7.4.

Las firmas **CAdES** se generarán con estructura attached que mantiene el documento original y la firma en un mismo fichero.

En el caso de que, debido al tamaño de los datos a firmar, no resulte técnicamente posible o aconsejable realizar las firmas con el formato anteriormente descrito, se generará la estructura de firma detached, que incluye el hash del documento original en la firma.

Las firmas **XAdES**, se generarán con la estructura “Internally detached”, es decir se genera un único fichero resultante que contiene el documento original, codificado en base64, y las firmas, encontrándose al mismo nivel XML lo firmado y la firma (se exceptúa la factura electrónica):

```
<documento>
  <documentoOriginal Id="original" encoding="base64" nombreFichero= nombreFichOriginal">
    ...
  </documentoOriginal>
  <ds:Signature>
    <ds:SignedInfo/>
    ...
    <ds:Reference URI="#documentoOriginal"> </ds:Reference>
    </ds:SignedInfo>
  ...
</ds:Signature>
</documento>
```

SELLADO DE TIEMPO

El sellado de tiempo y la información de validación pueden ser añadidos por el emisor, el receptor o un tercero y se deben incluir como propiedades no firmadas en el campo SignatureTimestamp

ALGORITMOS

Se admitirán las funciones de hash y los algoritmos de firma utilizados por las especificaciones XAdES y CAdES, de acuerdo con la especificación técnica ETSI TS 102 176-1 y aquellos algoritmos acreditados por el Centro Criptológico Nacional

Se podrán utilizar cualquiera de los siguientes algoritmos/resumen para la firma electrónica: RSA/SHA, RSA/SHA256 y RSA/SHA512.

PERFILES DE LOS CERTIFICADOS

Se establecen los campos obligatorios para los perfiles de los certificados definidos en el Real Decreto 1671/2009, de 6 de noviembre, por el que se desarrolla parcialmente la Ley 11/2007:

- Sede electrónica
- Sello electrónico
- Certificado electrónico de empleado público

1. CONCEPTOS DE CRIPTOGRAFIA
2. NORMATIVA DE FIRMA ELECTRONICA
3. CONCEPTOS DE FIRMA ELECTRONICA

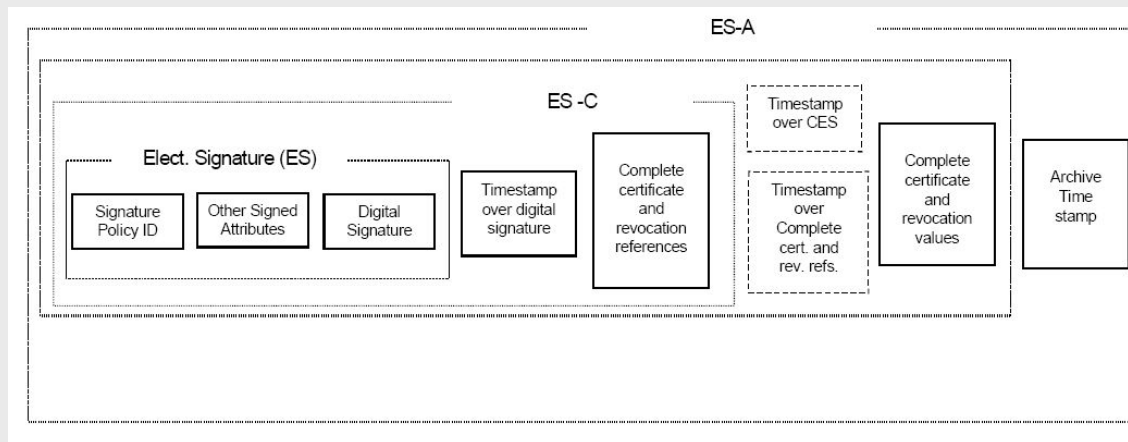
- Envoltorio para transportar/encapsular firmas digitales.
- Firma digital + información que permita su validación:
 - ◆ Atributos firmados
 - Hash de los datos
 - Tipo de envoltorio (*signed-data*)
 - Otra información a firmar (marca de tiempo...)
 - ◆ Certificado X.509 del firmante
 - ◆ Algoritmos empleados (hash, firma)
 - ◆ Firma digital de los atributos firmados
 - ◆ Datos (opcional) y su tipo
- Firmas Electrónicas attached ó detached.

- En función del formato de los elementos firmados, se pueden distinguir varios estándares:
 - ◆ **CMS: *Cryptographic Message Syntax***
 - Proviene de formato PKCS#7, un formato propietario de una empresa norteamericana (RSA)
 - Recomendación del IETF, RFC 2630, 3852.
 - Es especificada en notación abstracta ASN-1,
 - ◆ **XMLdsig: *XML Signature***
 - Recomendado por el W3C y RFC 3275
 - Basado y especificado en XML y sus correspondientes esquemas
 - Permite incorporar varias firmas en un documento, que afecten a diferentes partes
 - No es longeva.
 - ◆ **XAdES: *XML Advanced Electronic Signatures***
 - Estandarizado por ETSI TS 101 903
 - Permite incorporar información a la firma básica CMS: time-stamps, certificados de atributos, indicaciones de responsabilidades asumidas al firmar, etc).
 - Asegura la longevidad de las firmas
 - ◆ **CAdES: *CMS Advanced Electronic Signatures***
 - Normalizado por ETSI TS 101 733
 - Permite incorporar información a la firma básica definida por el W3C (XMLDsif): time-stamps, certificados de atributos, indicaciones de responsabilidades asumidas al firmar, etc).
 - Asegura la longevidad de las firmas
 - ◆ **Otros**
 - PDF, ODF, PGP, S/MIME

FORMATOS DE FIRMA ELECTRÓNICA

● Formatos avanzados en XML y CMS (XAdES y CAdES):

- ◆ **-EPES:** Incorporación de política de firma electrónica a las firmas básicas.
- ◆ **-BES:** Firma con un formato básico, incluyendo los atributos necesarios para la firma electrónica
- ◆ **-T:** Formato básico con sello de tiempos.
- ◆ **-C:** Completo, añadiendo referencias a datos de verificación (certificados y listas de revocación) a los documentos firmados para permitir la verificación fuera de línea y la verificación longeva
- ◆ **-X:** Extendido, añadiendo sellos de tiempo en las referencias introducidas por el formato -C para proteger contra el posible compromiso de validez en el futuro
- ◆ **-XL** Extendido de largo plazo, añadiendo certificados y listas de revocación al documento firmado para permitir la verificación en el futuro, incluso si su fuente original no estuviera disponible
- ◆ **-A:** Archivado, añadiendo la posibilidad de re-sello de tiempo periódico del documento archivado para prevenir el compromiso causado por la debilidad de los algoritmos de firma con el tiempo.



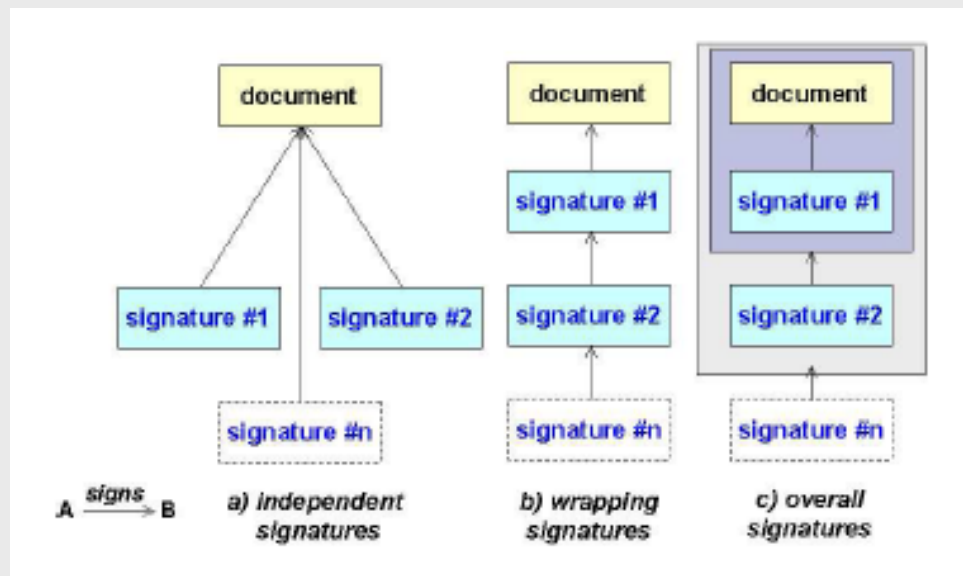
FIRMA ELECTRÓNICA DE DOCUMENTOS

- Existen múltiples formas de conformar la firma de documentos con independencia del formato de firma elegido.
- Se ha de poder recrear las situaciones de firma que se dan con la firma manuscrita
- Relación entre las firmas y documentos:

- ◆ Independientes o cosign
 - Se firma un documento por varios firmantes

- ◆ Cascada o countersign
 - El digest se forma con la firma anterior

- ◆ Global o de grupo
 - El digest se forma con la firma y el documento anterior

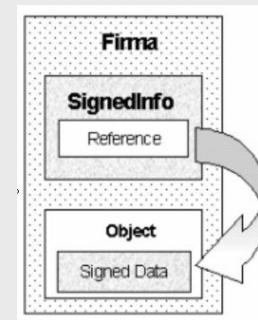


FIRMA ELECTRÓNICA DE DOCUMENTOS

- En función de la parte que se firma y la composición del bloque de firma, existen varios métodos, que dependen del formato de firma seleccionado:

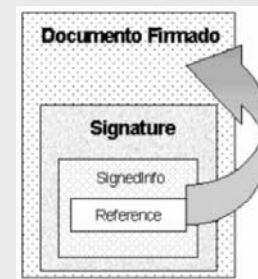
- ◆ **Envolvente - *enveloping***

- La estructura de firma incluye el mismo documento.
Eje: XMLDsig



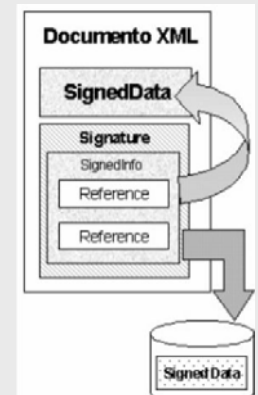
- ◆ **Envuelta - *enveloped***

- Se genera un nuevo documento con el documento inicial y la firma generada.



- ◆ **Independiente - *detached***

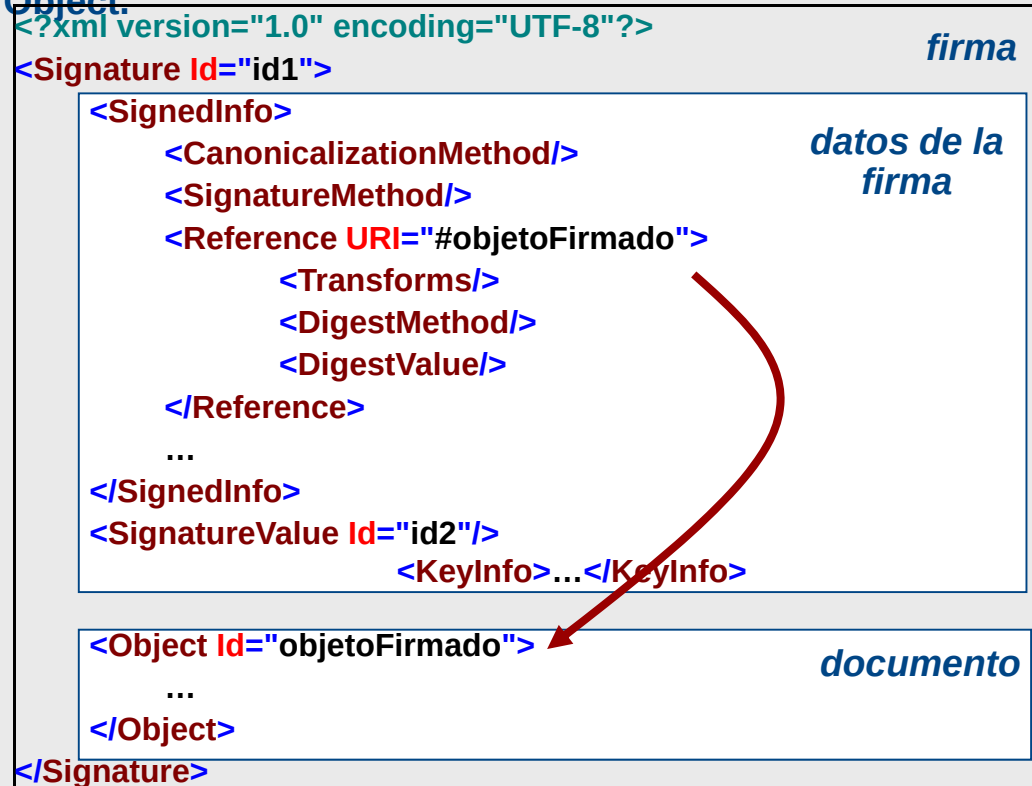
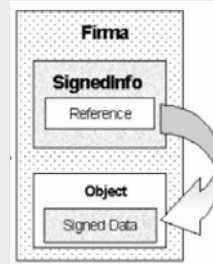
- En contra de los dos casos anteriores, documento y firma están en estructuras independientes.



FIRMA ELECTRÓNICA DE DOCUMENTOS

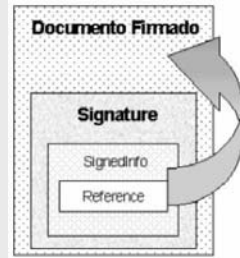
● Envoltente – *enveloping*

- ♦ La relación entre el objeto firmado y la firma electrónica se identifica por un parentesco hijo-padre
- ♦ El objeto firmado se introduce en un elemento *Object* perteneciente a la propia firma electrónica
- ♦ Para recuperar el documento original bastaría con obtener el contenido del elemento *Object*.



● Envuelta – *enveloped*

- ◆ La relación entre el objeto firmado y la firma electrónica está identificada por una relación de padre-hijo: El objeto firmado contiene la firma electrónica.
- ◆ Cuando se realiza una firma enveloped se realiza la firma del XML completo y se incluye en él la firma resultante
- ◆ Para recuperar los datos firmados bastaría con eliminar del XML la firma (elemento Signature).



```
<?xml version="1.0" encoding="UTF-8" standalone="no" ?>
<documento>
  cHJ1ZWJhIHBhcmEgZmlybWE
  - <ds:Signature xmlns:ds="http://www.w3.org/2000/09/xmldsig#" Id="Signature" xmlns:xades="http://uri.etsi.org/2001/05/xades" />
    - <ds:SignedInfo Id="Signature-SignedInfo">
      <ds:CanonicalizationMethod Algorithm="http://www.w3.org/TR/2001/REC-xml-c14n-20010315" />
      <ds:SignatureMethod Algorithm="http://www.w3.org/2000/09/xmldsig#rsa-sha1" />
      + <ds:Reference Id="Signature-Reference0" URI="" />
      + <ds:Reference Id="Signature-Reference1" Type="http://uri.etsi.org/01903/v1.2.2#SignedProperties" />
    </ds:SignedInfo>
    <ds:SignatureValue Id="Signature-SignatureValue">.....N1n6VPwC4c</ds:SignatureValue>
    + <ds:KeyInfo Id="Signature-KeyInfo">
    + <ds:Object Id="Signature-Object">
    </ds:Signature>
  </documento>
```

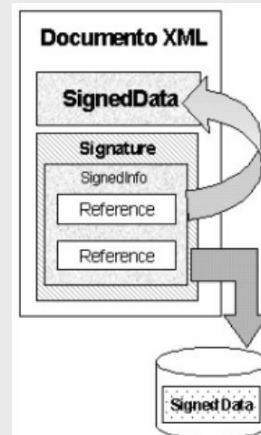

FIRMA ELECTRÓNICA DE DOCUMENTOS

● Independiente – *detached*

- ◆ La relación entre el objeto firmado y la firma electrónica no está identificada por relaciones de parentesco.
- ◆ La URI indicada en el objeto *Reference* indicaría el documento firmado, y puede ser a:

1. Referencia externa. En este caso se firmaría un documento que se encuentra fuera del XML.

2. Referencia interna. Se haría referencia a elementos dentro de un elemento XML padre.



```
<?xml version="1.0" encoding="UTF-8" standalone="no" ?>
<documento>
  <documentoOriginal Id="original1" MimeType="text/plain" encoding="base64" nombreFichero="prueba.txt">CHJ1ZWJhIHBhcmEgZmlybWE=</documentoOriginal>
  - <ds:Signature xmlns:ds="http://www.w3.org/2000/09/xmldsig#" Id="Signature" xmlns:xades="http://uri.etsi.org/01903/v1.2.2#">
    - <ds:SignedInfo Id="Signature-SignedInfo">
      <ds:CanonicalizationMethod Algorithm="http://www.w3.org/TR/2001/REC-xml-c14n-20010315" />
      <ds:SignatureMethod Algorithm="http://www.w3.org/2000/09/xmldsig#rsa-sha1" />
      + <ds:Reference Id="Signature-Reference0" URI="#original1">
      + <ds:Reference Id="Signature-Reference1" Type="http://uri.etsi.org/01903/v1.2.2#SignedProperties" URI="#Signature-SignedProperties">
      </ds:SignedInfo>
      <ds:SignatureValue Id="Signature-SignatureValue">X9InbkjvvHTt49ntoL4JxM7Vce6PzAq/OvH46HcZgtNV25ocHFtOrjIIThFA4R+xZPbSvJg0e6nd
      0AZzDKStzJOBANUdBmCwuVcR64D3Rsw58PecnP3ju3ci+emjA9mRVszQ+8R2fQGnt3m81fTvoe51 lgS5Tnqn4f27SEVitzk=</ds:SignatureValue>
      + <ds:KeyInfo Id="Signature-KeyInfo">
      + <ds:Object Id="Signature-Object">
      </ds:Signature>
    </documento>
```


Formato de Factura-e

- Algunos formatos de los más populares empleados:
 - ◆ PDF, RTF, Excel, ODF, HTML, XML, etc.
- El formato XML es el más versátil. Es un metalenguaje, y por lo tanto surgen diferentes lenguajes y semánticas:
 - ◆ ebXML (Electronic Business XML) y
 - ◆ UBL (Universal Business Language) -> es el más efectivo
- En España, el CCI (Centro de Cooperación Interbancaria) ha desarrollado un conjunto de recomendaciones. Respaldado por AEAT: AEAT-CCI: formato facturae
- Admiten muchos formatos de firma, pero se recomiendan los autocontenidas y avanzadas (XAdES-EPES, XAdES-C, XAdES-X-L -> elemento Xades:RevocationValues)